SECURITY ASSESSMENT REPORT

Security Assessment & Risk Analysis

Date Issued:
February 2026

Prepared for
NorthPeak Growth Marketing

Prepared by:
Roza Calloway

TABLE OF CONTENTS

1 **Executive Summary**
- Security Posture Overview
- Key Risks & Findings
- Recommendations Summary

2 **Introduction**
- Objectives
- Scope
- Out of Scope

3 **Assessment Methodology**
- Assessment Approach
- Risk Rating Methodology
- Risk Scoring Criteria

4 **Company Overview**
- Business Functions
- Critical Assets
- Organizational Structure & Operating Model

5 **Data & Access Overview**
- Data Classification
- Privileged Access & Roles
- Data Distribution & Exposure Risks

6 **Technology Environment**
- Systems & Tools Inventory
- Device Usage & Risk Levels

7 **Assumptions & Constraints**
- Security Domain Assumptions
- Assessment Constraints

8 **Threat Landscape**
- Key Threats
- Threat Categories & Risk Levels

9 **Control Assessment & Gap Analysis**
- Governance & Awareness Gaps
- Identity & Access Management (IAM)
- Data Protection
- Monitoring & Detection
- Application & Financial Controls

10 **Control Mapping to Frameworks**
- NIST CSF Alignment
- ISO 27001 Mapping
- Security Maturity Assessment

11 **. Key Findings**
- Weak MFA Enforcement
- Inadequate Credential Management
- Insecure File Sharing
- Lack of Formal Access Controls

12 **Risk Analysis & Visualization**
- Risk Heat Map
- Risk Dashboard
- Key Control Gaps

13 **Remediation Roadmap**
- Priority Actions
- Implementation Timeline

14 **Conclusion**

Executive Summary

This report presents the results of a security assessment conducted for NorthPeak Growth Marketing to evaluate its current cybersecurity posture and identify risks that could impact business operations, financial processes, and client trust.

The assessment identified key risks concentrated in identity and access management, credential security, and financial control processes. These risks are primarily driven by inconsistent implementation of foundational security controls rather than advanced external threats.

Overall, the organization demonstrates a developing level of security maturity, yet faces elevated exposure to common, preventable risks.

Addressing these gaps through targeted improvements—such as enforcing multi-factor authentication (MFA), strengthening access controls, and improving data handling practices—will significantly reduce the organization's risk exposure without disrupting operations.

This report provides prioritized recommendations and a remediation roadmap aligned with industry best practices to support ongoing risk reduction and security maturity.

Conclusion

The organization is primarily exposed to common threats rather than advanced attacks. These risks can be reduced through focused improvements in identity protection, credential management, and financial controls.

Security Posture

NorthPeak Growth Marketing operates with a functional but informal security approach. The organization relies heavily on cloud-based platforms and employee-managed processes, which support operational flexibility but introduce risk in identity management, access control, and data protection.

Security controls are present but inconsistently applied and lack formal governance. As a result, the organization is exposed to common, preventable threats.

Overall Posture: Developing maturity with elevated exposure to identity and credential-based risks.

Recommendations Summary

- Enforce MFA across all systems.
- Implement secure credential management practices.
- Strengthen financial transaction controls.
- Establish formal access control processes.
- Restrict file sharing and improve data handling practices.

Strengths

- Use of cloud-based platforms supports centralized operations.
- Partial MFA adoption is in place.
- Centralized systems provide a foundation for access control.

Introduction

The purpose of this assessment is to evaluate NorthPeak Growth Marketing's current security posture and identify risks that could impact business operations, financial processes, and client trust.

This assessment focuses on common, high-impact threats relevant to a small, cloud-based organization.

Objectives

The objective of this assessment was to Identify key security risks, Evaluate existing controls, Provide actionable recommendations, Improve overall security posture.

Scope

The assessment included the following:

- User devices and endpoint security
- Email and collaboration systems
- Identity and access management
- Cloud storage and SaaS platforms
- Network environment (limited scope)
- Data protection practices
- Backup and recovery processes
- Incident response readiness
- Security awareness
- Third-party/vendor dependencies

OUT OF SCOPE

The following areas were excluded:

- Application security testing
- Hardware-level security analysis
- Advanced cloud architecture review
- Physical security
- Advanced threat detection or SOC capabilities
- Underlying cloud infrastructure
- Legal or compliance certification

Assessment Methodology

This assessment was conducted using a risk-based approach aligned with industry best practices, including the NIST Cybersecurity Framework (CSF) and CIS Critical Security Controls.

The methodology included:

- Review of organizational processes, policies, and procedures
- Evaluation of identity and access management practices
- Analysis of cloud systems, email platforms, and endpoint usage
- Identification of common threat scenarios relevant to small, cloud-based organizations
- Assessment of existing security controls and gaps

Risk was evaluated based on Likelihood and Impact, using qualitative ratings (High, Medium, Low) to prioritize remediation efforts.

Risk Rating Table

Risk	Likelihood	Impact	Risk Level
Weak MFA Enforcement	High	High	High
Poor Credential Management	High	High	High
Insecure File Sharing	Medium	High	Medium
Lack of Formal Access Control	Medium	Medium	Medium
Limited Monitoring & Logging	Medium	Medium	Medium

Assessment Approach

This assessment was conducted through a structured review of business operations, systems, and data flows. No active testing or exploitation was performed.

Methodology

The assessment used a risk-based approach to identify security weaknesses across business operations, systems, and processes. The review included:

- Analysis of business context and critical assets
- Evaluation of identity and access controls
- Review of data handling and storage practices
- Identification of common threat scenarios
- Assessment of third-party and SaaS dependencies

The assessment reflects a point-in-time evaluation based on available information.

Risk Score Formula: Risk = Likelihood × Impact

Risk Rating Criteria

Risks were evaluated based on likelihood and business impact. Severity ratings are based on potential impact to business operations, financial integrity, and client trust.

Risk Rating Table

Severity	Impact
Critical	Immediate risk to financial systems, identity, or core business operations
High	Significant risk to sensitive data or client systems
Medium	Moderate operational or data exposure risk
Low	Limited impact or low likelihood

Company Overview

Business Functions

Function Area	Activities
Paid Advertising	Google Ads, Meta Ads, LinkedIn Ads
Organic Growth	SEO, content marketing
Web Services	WordPress, Webflow design
Customer Engagement	Email marketing campaigns
Performance Tracking	Analytics and reporting

Critical Assets

Asset	Description	Type
Google Workspace	Central platform for identity, email, and file storage.	SaaS
Advertising Platforms	Systems directly tied to campaign execution and revenue.	SaaS
Financial Systems	QuickBooks and Stripe used for financial operations.	SaaS
API Keys and Integrations	Access mechanisms connecting systems and services.	Data
Privileged Accounts	Accounts with elevated access across systems.	People
Client and Financial Data	Sensitive data supporting business operations & client services.	Data

Company Overview

Organizational Structure

CEO

```
│
├──── Operations Manager
│
├──── Marketing Team
├──── Web Team
├──── Sales & Account Management
├──── Finance/Admin
└──── IT Support (Contractor)
```

Operating Model

The organization follows a hybrid work model, with approximately 8–10 employees based in the office and the remaining workforce operating remotely.

Working Model	Description
Office	8-10 employees
Remote	Remaining staff

Data Overview

Data

Data Type	Sensitivity
Client Data	High
Internal Data	Medium
Financial Data	Critical
Credentials	Critical

Privileged Access

Role	Access Level	Systems / Data
CEO	Full	Email, financials, client relationships
Operations Manager	Admin	Internal tools, operations systems
Web Developers	High	Hosting, domains
Paid Ads Specialists	Scoped	Client ad accounts
It Contractor	Admin	Systems and infrastructure

Security Gap Identified

No formal password manager is in use, increasing the risk of credential compromise and uncontrolled access sprawl.

Technology Environment

Systems Inventory

Category	Tools
Productivity & Identity	Google Workspace
Storage	Google Drive
CRM	HubSpot
Advertising Platforms	Google Ads, Meta Business Manager, LinkedIn Campaign Manager
Web Platforms	WordPress, Webflow
Finance	QuickBooks Online, Stripe
Communication	Slack

Device Usage

Device Type	Users	Risk Level
Company-issued laptops	Leadership, developers	Lower
Personal devices (BYOD)	Some staff	Higher

Assumptions

The following assumptions were made during the assessment based on available information and observed practices. These assumptions highlight areas where formal controls or verification mechanisms may not be in place.

The organization relies on hardware, SaaS platforms, data assets, personnel, and third-party vendors to support operations. The environment is cloud-based and identity-driven. Most critical assets are accessed through user credentials. Compromised credentials could result in a significant business impact.

Security Domain	Assumptions
Identity & Access Management	• Google Workspace is the primary identity provider. • Multi-factor authentication (MFA) is not consistently enforced. • No centralized password manager is in use. • Access provisioning is manual and informal. • No formal offboarding process exists. • Contractors may retain access to systems beyond their engagement.
Endpoint & Device Management	• Employees use both company-issued and personal devices (BYOD) • Devices are not centrally managed or monitored.
Data Management & Storage	• Sensitive data is stored in shared Google Drive folders. • Public file-sharing links are actively used.
Monitoring & Security Operations	• Logging and monitoring capabilities are limited. • No centralized visibility into user or system activity
Security Awareness & Governance	• Security awareness training is minimal or not formally implemented. • No formal security policies or standards are established.
Application & Integration Management	• SaaS integrations and third-party connections are enabled without formal review or approval.
Financial Controls	• Financial processes rely on email-based approvals without secondary verification controls.

Constraints

The following constraints impacted the scope, depth, and execution of the assessment.

Type	Constraints
Budget	• Preference for low-cost or built-in security solutions • Limited budget for dedicated security tools or services
Time	• Limited availability of stakeholders for interviews • Limited existing documentation available for review
Resource	• No dedicated internal security team • IT responsibilities are managed by an external contractor.
Security Maturity	• Low overall security awareness across the organization • Potential resistance to implementing additional security controls
Operational	• Security improvements must not disrupt ongoing business operations. • Solutions must align with a fast-paced, client-service environment.

Asset Categories

Category	Description
Hardware and Network Infrastructure	Company-issued laptops and personal devices used for system access. Office network managed by an external contractor.
SaaS Applications and Core Platforms	Google Workspace, Google Drive, HubSpot, advertising platforms, WordPress/Webflow, QuickBooks, Stripe, Slack.
Data Assets	Client campaign data, financial records, credentials, API keys.
People and Access Roles	Employees and contractors with varying access levels, including privileged users.
Third-Party Vendors and Dependencies	Managed IT provider, platform providers, payment processors, freelancers and contractors.

Data Classification

The organization processes data with varying levels of sensitivity.

Classification	Description	Examples
Restricted	Highest sensitivity; limited access	Financial records, payment data, administrative credentials, API keys, client account access, banking information
Confidential	Sensitive business and client data	Campaign data, analytics, client contacts, internal documentation, contracts
Internal	Internal-use information	Communications, SOPs, meeting notes, non-sensitive HR data
Public	Publicly available information	Website content, marketing materials, social media

Data Distribution

- Google Workspace / Drive: over-permissioning and public sharing risk
- HubSpot: unauthorized access or data export risk
- Advertising Platforms: financial and client impact risk
- Financial Systems: fraud risk
- Slack: sensitive information exposure risk

Key Insight

Sensitive data is widely distributed across cloud platforms and primarily protected through user credentials. Misconfigured access or compromised accounts could expose significant data.

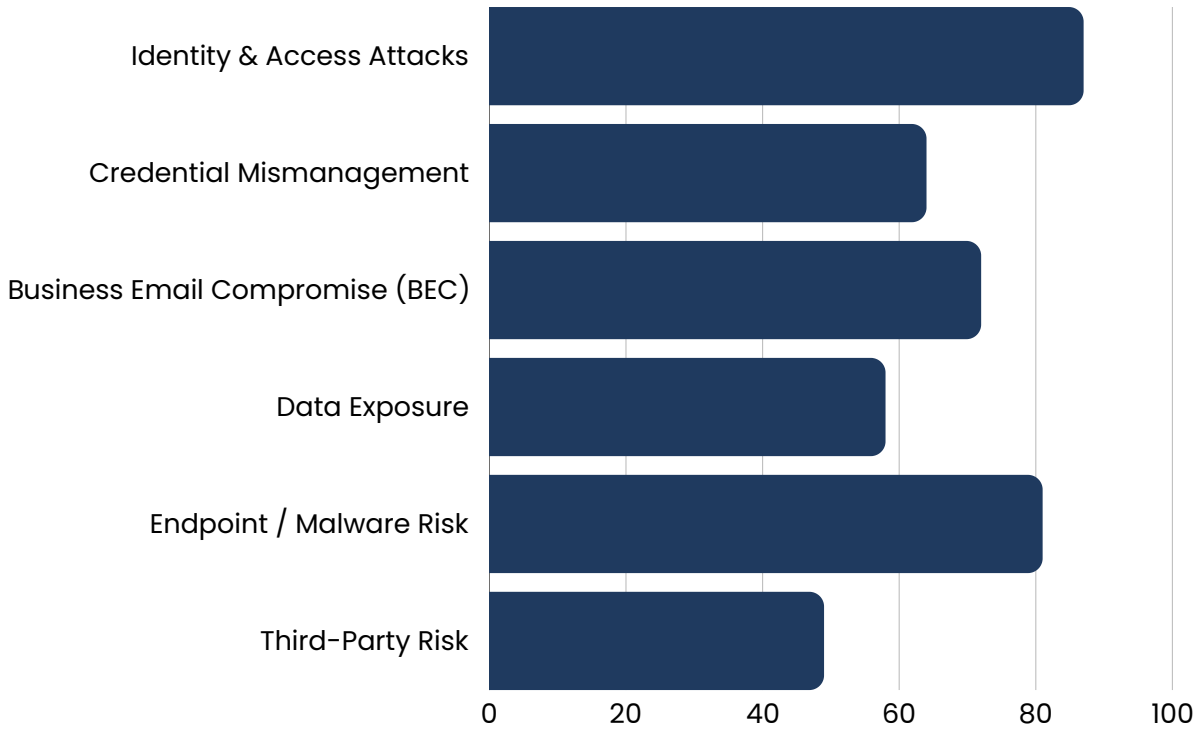
The data environment is centralized in cloud platforms but broadly accessible. Misconfigured permissions or compromised credentials could expose sensitive data.

Threat Landscape

Top Threats

- Account compromise through phishing and credential theft
- Financial fraud via email-based payment or invoice manipulation
- Unauthorized access due to shared or reused credentials
- Excessive or unmanaged access across systems
- Data exposure through uncontrolled file sharing

Threat by Risk Level



Summary Insight

The threat landscape is primarily driven by common attack methods targeting identity, access, and financial processes. These risks are closely tied to gaps in credential management, access control, and data handling practices. Addressing these foundational control weaknesses will significantly reduce the organization's exposure to high-frequency, high-impact threats.

The majority of identified threats are preventable through improved implementation of foundational security controls.

Control Mapping

The assessment identified several gaps in foundational security controls across identity management, data protection, monitoring, and governance. These gaps increase the organization's exposure to common and preventable cybersecurity risks.

Identity & Access Management

- Inconsistent enforcement of multi-factor authentication (MFA)
- No centralized password management solution
- Manual user provisioning and delayed offboarding
- Uncontrolled third-party and contractor access

Data Protection

- Over-permissioned access to shared storage
- Unrestricted file-sharing practices
- Absence of a data classification framework

Monitoring & Detection

- Limited logging capabilities across systems
- No centralized alerting or incident detection

Governance & Awareness

- No formal security policies or standards
- Lack of structured security awareness training

Application & Financial Controls

- No SaaS or third-party risk review process
- Over-privileged access across applications
- Weak transaction authorization controls

Security Maturity

Function	Score	Coverage
Identify	2	Low
Protect	2	Low
Detect	1	Very Low
Respond	1	Very Low
Recover	1	Not Assessed

Control Mapping to Indusrty Framework

Control Gap	NIST CSF	ISO 27001	Description
Inconsistent MFA	PR.AC-7	A.9.4.2	Authentication controls not enforced
No password manager	PR.AC-1	A.9.2.4	Weak credential management practices
No device management	PR.IP-1	A.8.1.1	Lack of asset and device control
Public file sharing	PR.DS-1	A.13.2.1	Unrestricted data sharing
Limited logging	DE.CM-1	A.12.4.1	Insufficient event logging
No alerting	DE.CM-7	A.16.1.2	No detection or response triggers
No security policies	ID.GV-1	A.5.1.1	Lack of governance framework
Email-based approvals	PR.AC-3	A.9.4.1	Weak transaction authorization

Insight

The majority of control gaps align with the Protect (PR) and Detect (DE) functions of the NIST Cybersecurity Framework, indicating weaknesses in preventing unauthorized access and detecting security events.

Strengthening identity controls, monitoring capabilities, and governance processes will significantly reduce organizational risk exposure.

Key Findings

The following findings summarize the most significant risks identified during the assessment. These findings are prioritized based on business impact and likelihood.

1. Weak Multi-Factor Authentication (MFA) Enforcement

Risk: High

Impact: Unauthorized account access, potential compromise of business systems and client data

Description: MFA is not consistently enforced across all systems, increasing the risk of account compromise through phishing or credential theft.

Recommendation: Enforce MFA across all user and administrative accounts.

2. Inadequate Credential Management

Risk: High

Impact: Increased likelihood of account compromise and unauthorized access

Description: Employees rely on weak or reused passwords without centralized credential management practices.

Recommendation: Implement password policies and encourage the use of password managers.

3. Insecure File Sharing Practices

Risk: Medium

Impact: Potential data leakage or unauthorized access to sensitive business information

Description: File sharing is not consistently controlled or monitored across cloud platforms.

Recommendation: Restrict sharing permissions and implement data handling policies.

4. Lack of Formal Access Control Processes

Risk: Medium

Impact: Unauthorized or excessive access to systems and data

Description: Access rights are not consistently reviewed or documented.

Recommendation: Establish role-based access control (RBAC) and periodic access reviews.

Risk Dashboard

Executive Summary

The organization faces elevated cybersecurity risk driven by weaknesses in identity management, credential security, and financial control processes.

The majority of risks are high likelihood and high impact, indicating exposure to common and preventable threats rather than advanced attacks.

Strengthening foundational controls, particularly MFA, access management, and monitoring, will significantly reduce overall risk exposure.

Risk Heat Map

High-risk areas are concentrated in identity management and financial processes, where both likelihood and impact are elevated.

```
                    IMPACT →
                Low       Medium        High
            ------------------------------------
High        |            |              | 🔴 MFA Gaps
(Likelihood)|            |              | 🔴 Credential Mgmt
            |            |              | 🔴 Financial Fraud (BEC)
            ------------------------------------
Medium      |            | 🟠 Data      | 🟠 Access Control
            |            | Exposure     | 🟠 Third-Party Risk
            |            | 🟠 Monitoring|
            ------------------------------------
Low         |            |              |
            |            |              |
            |            |              |
            ------------------------------------
              Low        Medium        High
                    LIKELIHOOD ↑
```

Key Control Gaps

- No centralized password management
- No enforced MFA across systems
- No device management (MDM)
- No formal access control or offboarding
- No security awareness program
- No monitoring or alerting capabilities

Remediation Roadmap

The remediation roadmap prioritizes high-impact, low-complexity controls to address the organization's most critical risks. The recommended actions focus on strengthening identity protection, credential management, and financial controls while minimizing disruption to business operations.

Priority	Action	Timeline
High	Enforce MFA across all systems	30 days
High	Implement password management practices	30 days
Medium	Restrict file sharing & improve data handling	60 days
Medium	Establish access control processes	60–90 days
Low	Improve monitoring and logging	90 days

Priority Focus Area

- Identity protection
- Credential management
- Financial controls
- Access governance

Conclusion

The organization is primarily exposed to common, preventable cybersecurity risks rather than advanced threats.

By focusing on foundational security controls, particularly identity protection, credential management, and access control, the organization can significantly reduce its risk exposure.

By implementing the recommended actions, NorthPeak Growth Marketing can transition from a developing security posture to a more mature, resilient cybersecurity program aligned with industry best practices.